

Unifolio — Data Retention & Deletion Policy

Effective date: 2026-05-13

Last reviewed: 2026-05-13

Owner: Ahmed Al-Samak, CEO (security@unifolio.ca)

Review cadence: Annually, or upon material change to data architecture or applicable privacy law.

1. Purpose

This policy defines how long Unifolio retains each category of user data, when and how that data is deleted, and how deletion is verified. It implements the retention commitments made in our **PRIVACY_POLICY.md** and ensures compliance with PIPEDA (Canada), GDPR (EU/UK), and the Plaid Production Customer Agreement.

2. Data classes and retention schedule

Data class	Examples	Retained while account active?	Retention after deletion request	Backup retention
Account identity	Email, name, password hash, profile photo	Yes	Hard-deleted within 24 hours	Per Supabase tier (currently 7 days on Free)
Portfolio data	Holdings, transactions, realized positions, custom assets (real estate, metals, collectibles, etc.), ACB history	Yes	Hard-deleted within 24 hours	Per Supabase tier (currently 7 days on Free)
Plaid connection data	<code>item_id</code> , <code>access_token</code> , institution metadata	Yes	Database record hard-deleted within 24 hours by the full-account-delete cascade. The <code>access_token</code> is simultaneously revoked via Plaid's <code>/item/remove</code> API by the <code>/api/account/delete-all</code> serverless function	Per Supabase tier (currently 7 days on Free)

Data class	Examples	Retained while account active?	Retention after deletion request	Backup retention
			— terminating the connection at the bank end as well.	
Imported broker files	Raw CSV/Flex/PDF uploads	Never stored — only parsed positions/transactions are saved	N/A	N/A
Profile picture asset	Image file in Supabase Storage	Yes	Deleted from Storage immediately on account deletion	Per Supabase tier (currently 7 days on Free)
Transient session data	Auth tokens, session cookies	Until user signs out or 7-day session timeout	Cleared immediately on sign-out	N/A
Operational audit signals	Supabase Auth <code>auth.audit_log_entries</code> (sign-ins, password changes, account deletions); Supabase Postgres logs; Vercel function logs	Yes (vendor-managed)	Retained per Supabase tier policy (currently 7 days on Free; longer on Pro). Application-level audit table is on the 2026 roadmap (see §3.4).	Per Supabase tier
Email correspondence	Support emails, password reset emails	Stored in Microsoft 365 mailbox	Anonymized or deleted on user request	Per Microsoft 365 policy
Marketing opt-in records	Subscriber list (if applicable)	Until unsubscribe + 30-day suppression list	Removed within 30 days of unsubscribe	N/A

3. Deletion mechanism

3.1 User-initiated deletion (self-service)

Users can permanently delete all their data via:

Settings → **Privacy & Data** → **Delete All Data**

The flow:

1. User confirms deletion via a 2-step modal (`DeleteConfirmModal` in `src/pages/PrivacyAndData.jsx`) with a checkbox confirming the action is irreversible.
2. The frontend calls the `delete_unifolio_user_data` Postgres RPC (defined in `supabase/schema.sql`), which deletes the user's rows from: `holdings` , `realized_positions` , `transactions` , `import_batches` , `watchlist` , `accounts` , `institutions` , `user_profiles` . The Supabase Storage `avatars/<user_id>` asset is also deleted from the `avatars` bucket.
3. The frontend then calls the `/api/account/delete-all` Vercel serverless function (`api/account/delete-all.js`) with the user's session JWT. This server-side endpoint, holding the Plaid client secret and the Supabase service-role key (both stored only as Vercel environment variables, never exposed to the browser), performs:
 - **Plaid `/item/remove` API call** for every `plaid_items` row belonging to the user, revoking the `access_token` at Plaid's end and terminating the bank-side connection.
 - **Hard-delete of all `plaid_items` rows** belonging to the user from Supabase.
 - **Permanent removal of the `auth.users` record** via `supabase.auth.admin.deleteUser()` . After this completes, the user cannot authenticate; the account no longer exists.
1. The frontend then calls `supabase.auth.signOut()` to terminate any remaining local session and dispatches a portfolio-deleted event so the UI lands on the public Welcome page.
2. Local browser caches (theme, currency, watchlist, profile picture cache) are cleared by the frontend.
3. The deletion is captured in Supabase's built-in audit infrastructure (see §3.4): the RPC invocation is logged in Supabase Postgres logs, the HTTP request is logged in Vercel function logs, and the `auth.admin.deleteUser` call is logged in `auth.audit_log_entries` . Unifolio does not currently maintain an additional application-level audit row beyond these vendor-managed logs.

3.2 Account-level deletion (Accounts page)

Users can delete an individual account (one brokerage) without deleting their full Unifolio profile. This:

- Cascades through the account's `holdings` , `transactions` , `realized_positions` , `import_batches` .
- Prunes the parent `institution` row if no other accounts reference it (handled by the `delete_unifolio_account` RPC).
- Revokes the relevant Plaid `access_token` if the account was Plaid-connected.

3.3 Inactive-account expiry

Currently we do **not** auto-delete inactive accounts. If we introduce auto-expiry in future, we will:

- Notify the user 30 days before deletion via email.
- Default to a 24-month-of-inactivity threshold.
- Update this policy and notify users of the change.

3.4 Audit trail

Unifolio writes a structured `audit_log` row for every security-relevant event the user takes, with a structured `possession_id` row. With every security-relevant event the user takes, Unifolio

- **Auth events:** `auth_signin` , `auth_signout` , `auth_signup` , `email_changed` , `password_reset_requested` .
- **Multi-factor authentication:** `mfa_enrolled` , `mfa_unenrolled` , `mfa_challenge_succeeded` , `mfa_challenge_failed` (added once consumer MFA ships).
- **Data lifecycle:** `account_deleted` , `account_partial_delete` , `data_export_csv` , `data_export_json` .
- **Plaid lifecycle:** `plaid_token_revoked` , `plaid_item_disconnected` , `plaid_webhook_received` , `plaid_item_error_state` , `plaid_item_reconnected` .
- **Custom asset CRUD:** `custom_asset_created` , `custom_asset_updated` , `custom_asset_deleted` .

Each row contains: `user_id` (UUID, not the email), `event_type` (allowlisted), `actor` ('self' | 'system'), `metadata` (small JSON tag with non-PII context such as item IDs, counts, asset types), `ip` , `user_agent` , and `created_at` . Writes go through the `/api/audit/write` Vercel serverless function using a service-role Supabase client; clients cannot insert directly (the RLS policy is read-only for the authenticated user).

In addition to the application audit table, Unifolio relies on:

- **Supabase Auth's built-in `auth.audit_log_entries` table** (managed by gotrue) for sign-in / password-change / email-change events with full IP context.
- **Supabase Postgres logs** for every API call hitting our deletion RPCs.
- **Vercel function logs** for every HTTP request, including the deletion endpoint.

The `audit_log` table itself is retained indefinitely while the user's account is active and is hard-deleted along with the user's other data when the account is deleted (rows reference `auth.users` with `on delete set null` , so historical security investigations remain possible at the operator level for reasonable forensic timeframes).

4. Backup retention

Supabase performs **automated daily backups** of the entire Postgres database according to its tier policy (Unifolio is currently on Supabase Free, which provides daily backups). Backup storage is encrypted at rest by AWS KMS and access is restricted to Supabase staff under their SOC 2 II controls.

After a deletion request:

- The deleted record is gone from the **live database** within 24 hours.
- It may persist in **encrypted backup snapshots** for up to the Supabase tier-defined retention window (currently 7 days on Free tier) before backup rotation purges it.
- Backup data is **only ever accessed for disaster recovery** and is never used for normal queries.

Point-in-time recovery (PITR) and longer backup retention will be enabled when Unifolio upgrades to Supabase Pro (trigger: first ≥ 5 paying users or any incident requiring sub-day recovery).

If a user explicitly requests their data be removed from backups before the rotation window completes (a rare GDPR request), we will document the request and confirm completion within an additional 30 days.

5. Plaid-specific retention

Per the Plaid Production Customer Agreement:

- Plaid `access_token` revocation via `/item/remove` is performed immediately when the user explicitly disconnects an Item from Settings.
 - On full account deletion, the same `/item/remove` call is made automatically (looped over every `plaid_items` row belonging to the user) by the `/api/account/delete-all` serverless function, and the `plaid_items` rows are hard-deleted from Supabase within 24 hours.
 - Plaid `item_id` and institution metadata are deleted from our database within 24 hours of any deletion request.
 - Cached Plaid account/transaction data is deleted alongside the rest of the user's portfolio data.
 - Unifolio retains no Plaid Link credentials at any point — Plaid handles all underlying broker authentication.
-

6. Export rights

Before deletion, users can export their full data via:

Settings → Privacy & Data → Export your data

Exports include:

- Full JSON dump of all portfolio data
- Holdings CSV
- Transactions CSV
- Realized gains CSV

These are generated client-side from the user's own data and downloaded directly to their device — no copy is created on our servers.

7. Verification & monitoring

- After every account-deletion request, the CEO spot-checks Supabase's `auth.audit_log_entries` and Postgres RPC logs (within their tier-defined retention window) to confirm the deletion event succeeded and no orphaned records remain.
- A quarterly query is run to detect any potential orphans:

```
```sql
-- Holdings without a matching auth.users row
SELECT COUNT(*) FROM holdings h
LEFT JOIN auth.users u ON u.id = h.user_id
WHERE u.id IS NULL;
```

```
``` Data Retention and Disposal Policy · Unifolio Inc. · Generated 2026-05-14 · Canonical version: github.com/2uay/unifolio
```

- Any orphaned rows discovered are deleted manually within 7 days and the deletion query is re-run to confirm.
-

8. Records of processing

Per GDPR Article 30, Unifolio maintains records of processing activities. These are documented in:

- **PRIVACY_POLICY.md** — public-facing summary
- **INFOSEC_POLICY.md** — internal vendor + data-flow inventory
- This document — retention specifics

The combined set is reviewed annually by the CEO.

9. Policy changes

This policy is reviewed and updated:

- **Annually** at minimum.
- **On any material change** to deletion procedures, retention windows, or applicable regulation.

The change history is the Git commit history of this file in the public Unifolio repository.

Acknowledgement

— Ahmed Al-Samak, CEO, Unifolio Inc.
2026-05-13